SLOVENSKI STANDARD
oSIST prEN 18246:2025

01-oktober-2025

Digitalni potni list za proizvode - Preverjanje pristnosti, zanesljivost in celovitost podatkov

Digital product passport - Data authentication, reliability and integrity

Digitaler Produktpass - Datenauthentifizierung, Zuverlässigkeit und Integrität

Passeport numérique des produits - Authentification, fiabilité et intégrité des données

Ta slovenski standard je istoveten z: **prEN 18246**

ICS:

13.020.20	Okoljska ekonomija. Trajnostnost	Environmental economics. Sustainability
35.240.63	Uporabniške rešitve IT v trgovini	IT applications in trade

oSIST prEN 18246:2025 **en,fr,de**

2003-01.Slovenski inštitut za standardizacijo. Razmnoževanje celote ali delov tega standarda ni dovoljeno.

oSIST prEN 18246:2025

EUROPEAN STANDARD

NORME EUROPÉENNE

EUROPÄISCHE NORM

DRAFT
prEN 18246

August 2025

ICS 13.020.20; 35.240.63

English version

Digital product passport - Data authentication, reliability and integrity

Digitaler Produktpass - Datenauthentifizierung, Zuverlässigkeit und Integrität

This draft European Standard is submitted to CEN members for enquiry. It has been drawn up by the Technical Committee CEN/CLC/JTC 24.

If this draft becomes a European Standard, CEN and CENELEC members are bound to comply with the CEN/CENELEC Internal Regulations which stipulate the conditions for giving this European Standard the status of a national standard without any alteration.

This draft European Standard was established by CEN and CENELEC in three official versions (English, French, German). A version in any other language made by translation under the responsibility of a CEN and CENELEC member into its own language and notified to the CEN-CENELEC Management Centre has the same status as the official versions.

CEN and CENELEC members are the national standards bodies and national electrotechnical committees of Austria, Belgium, Bulgaria, Croatia, Cyprus, Czech Republic, Denmark, Estonia, Finland, France, Germany, Greece, Hungary, Iceland, Ireland, Italy, Latvia, Lithuania, Luxembourg, Malta, Netherlands, Norway, Poland, Portugal, Republic of North Macedonia, Romania, Serbia, Slovakia, Slovenia, Spain, Sweden, Switzerland, Türkiye and United Kingdom.

Recipients of this draft are invited to submit, with their comments, notification of any relevant patent rights of which they are aware and to provide supporting documentation.Recipients of this draft are invited to submit, with their comments, notification of any relevant patent rights of which they are aware and to provide supporting documentation.

Warning : This document is not a European Standard. It is distributed for review and comments. It is subject to change without notice and shall not be referred to as a European Standard.





CEN-CENELEC Management Centre:
Rue de la Science 23, B-1040 Brussels

© 2025 CEN/CENELEC All rights of exploitation in any form and by any means reserved worldwide for CEN national Members and for CENELEC Members.

oSIST prEN 18246:2025

Contents

Page

European foreword 4
Introduction 5
1 Scope 6
2 Normative references 6
3 Terms and definitions 6
4 General security assumptions for DPP 7
4.1 General 7
4.2 Actors of the system 7
4.3 Access to public DPP data 7
4.4 Communication 8
4.5 Product identifier as stored in data carrier 8
4.6 Data carrier authenticity 8
4.7 DPP data authentication 8
4.8 Electronically signed data constructs (ESDCs) 9
4.8.1 Introduction to ESDCs 9
4.8.2 General services of ESDCs 9
4.8.3 General implementation principles of ESDCs 9
5 Types of risk and requirements for unique product identifiers, data carriers and DPP Data 10
5.1 Risk on data security and privacy 10
5.1.1 General 10
5.1.2 Protection of personal data 10
5.1.3 Security of personal data 10
5.1.4 Security of organizational data 11
5.1.5 Prevention of profiling 11
5.1.6 Ensuring safe user behaviour 11
5.1.7 Protection against phishing, quishing, and malicious code 11
5.1.8 Safeguarding against mass data scraping 11
5.2 Risk and requirements on identification 11
5.2.1 General 11
5.2.2 Authentication and traceability of responsible actors 12
5.2.3 Alignment between data providers and product manufacturers 12
5.3 Risk to products 12
5.3.1 Protecting against counterfeiting 12
5.3.2 Risks to DPP-related product fraud 12
5.4 Risk and requirements related to fair competition 12
5.4.1 General 12
5.4.2 Avoiding market restrictions by vendor specific software 12
5.4.3 Disproportionate resource demand for SMEs 13
5.5 Risk and requirements to prevent exclusion 13
5.5.1 General 13
5.5.2 Accessibility to a DPP with any consumer device 13
5.5.3 Accessibility for persons with disabilities 13
Annex A (informative) Examples of electronically signed data constructs (ESDCs) 14

oSIST prEN 18246:2025

A.1 General 14

A.2 Electronic attestation of attributes 14

A.3 Visible digital seal (VDS - ISO 22376) 14

A.4 Digital Signature Data Structure (DigSig - ISO/IEC 20248) 16

Annex ZA (informative) Relationship between this European Standard and the essential requirements of Regulation (EU) 2024/1781 establishing a framework for the setting of ecodesign requirements for sustainable products aimed to be covered 18

Bibliography 19

oSIST prEN 18246:2025

European foreword

This document (prEN 18246:2025) has been prepared by Technical Committee CEN/CLC/JTC 24 “Digital product passport – Framework and systems”, the secretariat of which is held by DIN.

This document is currently submitted to the CEN Enquiry.

This document has been prepared under a standardization request addressed to CEN by the European Commission. The Standing Committee of the EFTA States subsequently approves these requests for its Member States.

For the relationship with EU Legislation, see informative Annex ZA, which is an integral part of this document.

oSIST prEN 18246:2025

Introduction

Regulation (EU) 2024/1781 establishing a framework for the setting of ecodesign requirements for sustainable products related to digital product passports (ESPR - DPP) expect end-to-end reliability throughout the entire ecosystem. Trust is key to any transaction whether physical or digital. Data and information collected during the whole life cycle of the product is to be protected from both accidental and malicious compromise and misuse.

Any security assessment is likely to address the following elements of the DPP deployment:

— management and verification of identifiers;

— relationship between the unique identifiers and possible authentication elements related to them;

— questions that deal with the identification of the verifier and any authorized access to privileged product related information;

— verifier access history (logs);

— authentication solutions;

— artefact metrics, where relevant;

— information processing and communication that protects integrity along the supply chain of physical and related electronic documents, products, software and services life cycle to mitigate the risk of product fraud and counterfeit goods, by using object identification techniques, and

— verifiable credentials or equivalent functions.

A wide variety of information security techniques are routinely deployed at scale and at different levels. For example, the banking, retail, and entertainment industries are global, connected, and always available. The EU DPP system should leverage industry standards and best practices in all aspects of the DPP solution, from data generation by the economic operator and data storage in distributed data centres, through to the management of access rights for data access and data queries. The DPP end users, product owners, and enforcement agencies will all benefit from a trustworthy DPP infrastructure.

The unique product identifier, as stored in a data carrier can be considered as the DPP access anchor. Trust in the identifier is therefore a foundational element to the trust of DPP.

oSIST prEN 18246:2025

1 Scope

This document defines the requirements and frameworks for secure information processing and communication to safeguard integrity, authenticity and reliability in the digital product passport (DPP) data exchange, minimizing product fraud and counterfeiting through data verification and integrity enforcement mechanisms.

This document provides a framework for establishing trust, interoperability, and interoperation via secure electronically signed data construct (ESDC) for multi-actor applications, applicable across various sectors and in multilingual environments. Existing hardware and software systems for unique product identification and storage of this identification are to be considered.

The following is out of the scope of this document: system architecture for DPP, DPP use cases, secure elements related to data carriers and cryptographic security features for unique product identifiers.

NOTE 1 While not disrupting existing traceability and authentication systems, this document facilitates interoperability by introducing an ESDC scheme to be combined with existing data constructs to cover and preserve existing data models.

NOTE 2 Annex A includes illustrative examples and references to supporting implementations, intended to demonstrate approaches that promote interoperability across diverse environments. These references are provided to assist stakeholders in selecting appropriate solutions that comply with applicable legal obligations and technical standards, while preserving existing systems.

2 Normative references

The following documents are referred to in the text in such a way that some or all of their content constitutes requirements of this document. For dated references, only the edition cited applies. For undated references, the latest edition of the referenced document (including any amendments) applies.

prEN 18220:2025, *Digital product passport - Data carriers*

3 Terms and definitions

For the purposes of this document, the following terms and definitions apply.

ISO and IEC maintain terminology databases for use in standardization at the following addresses:

— ISO Online browsing platform: available at https://www.iso.org/obp/

— IEC Electropedia: available at https://www.electropedia.org/

3.1
electronically signed data construct
ESDC
structured data set containing the header, payload, signature and optional data fields

Note 1 to entry: The payload type and issuer identity are included in the header.

Note 2 to entry: An ESDC is a machine-readable code.

Note 3 to entry: An ESDC can contain non-signed data elements

3.2
digital product passport
DPP
digital record of product characteristics throughout its life cycle

oSIST prEN 18246:2025

Note 1 to entry: Example characteristics include environmental sustainability, environmental impact, and recyclability

3.3
unique product identifier
unique string of characters for the identification of a product that also enables a web link to the digital product passport

4 General security assumptions for DPP

4.1 General

The DPP provides required information for products. Product information consists of public and controlled data.

All data flows should be verifiable, both the data and the source of the data to ensure trust in the DPP.

NOTE 1 The data verifiability starts with the unique product identifier.

NOTE 2 ISO 22380 outlines principles for addressing physical product fraud, focusing on authenticity, integrity, and trust for products and documents. It provides guidelines for organizations to identify and mitigate risks associated with *inter alia* product fraud, which can range from counterfeiting to tampering and substitution. The standard emphasizes the importance of understanding the situational context of fraud, including the motives and behaviours of fraudsters, to develop effective countermeasures. Types of fraud addressed include recreational, occasional, occupational professional and activism fraud and misinformation.

4.2 Actors of the system

All actors within a DPP system, except the public, shall be globally identified by a unique operator identifier.

All such actors shall be authenticated via a trustworthy process.

NOTE 1 Actors within the DPP system are defined in prEN 18239.

NOTE 2 The unique operator identifier is defined in prEN 18219.

NOTE 3 Actors accessing not restricted data (public part the DPP) are not subject to identification or authentication requirements.

4.3 Access to public DPP data

Consumer access to DPP data, limited to reading purposes, differ from other use cases due to the following considerations:

— No Authentication Required: Accessing public data shall not require authentication.

— Privacy Considerations: Privacy measures are needed to prevent profiling of user interests.

— Ease of Use and Scalability: The access control of DPP data shall be capable of handling a large number of requests without compromising usability.

— User Safety: The platform shall be safe for all users.

— Compatibility: Smart devices, without the need for additional software, should be able to retrieve DPP data from DPP services.

oSIST prEN 18246:2025

— Optional Additional Security: Enhanced security features could be provided through an official app by the European Commission or an authority, or integration with wallets or digital services of legal authorities. However, this should remain optional, as not all devices used by consumers may support such applications. Consumer access to DPP data shall remain available regardless of the device.

— Access to public DPP data for consumers shall be possible without the need for download of additional software

4.4 Communication

Communication within the DPP context refers to the transmission of product related information between stakeholders, ensuring that all involved parties, such as manufacturers, regulators, and consumers, have access to accurate relevant and up-to-date data.

The communication of this data shall be secure, using encryption and authentication methods in accordance with relevant standards (such as ETSI EN 319 401:2024) to prevent tampering, unauthorized access, or data breaches, maintaining the integrity and confidentiality of the DPP.

NOTE EU legal acts for trust services can also apply.

Seamless and interoperable communication channels shall be established to allow different systems and actors to exchange DPP data, ensuring compatibility across various platforms and regulatory frameworks at national and international levels.

4.5 Product identifier as stored in data carrier

The authenticity and integrity of the data in the data carrier should be ensured with a high level of security protecting the data from unauthorised modifications and supporting non-repudiation.

Any solution for ensuring the authenticity and integrity of the product identifier should be fully interoperable with the unique identifiers as defined in prEN 18219.

Such solutions may require additional data carrier(s).

While specific software may be used to enable users to verify the authenticity and integrity of the product identifier, at least one data carrier on each product should allow users to access the DPP data without the need for additional software.

4.6 Data carrier authenticity

The economic operator should secure the physical authenticity of the data carrier, when justified by a value/cost relationship or mandated by law.

Any solution for ensuring the physical authenticity of the physical data carrier shall be fully interoperable with the data carriers as they are defined in prEN 18220:2025.

Such solutions may require additional data carrier(s).

While specific software may be used to enable users to verify the physical authenticity of the data carrier(s), the protected data carrier shall allow users to access the DPP data without the need for additional software.

4.7 DPP data authentication

A DPP should be verifiable in term of authenticity and integrity of the data and the identity of the economic operator through interoperable mechanisms in the regulated cross-border scenarios.

Checking the validity and the integrity of the data managed by the DPP shall be for free of charge and limitations for the verifier.

The following scenarios are possible:

oSIST prEN 18246:2025

— no verification (user is not obliged to verify the DPP);

— verification by the receiving application;

— verification via a third party;

— other solutions as mandated by law.

Any creation, modification, or deletion of data within the DPP system shall be logged in a non-repudiable and legally binding manner.

This should be ensured through the use of digital signatures or digital seals, without the need for additional supporting documents or offline procedures.

The responsible editor of any change shall be identifiable through a globally unique operator identifier, as well as the system or individual user executing the change.

Any event that modifies a DPP during its operational phase shall be logged in an audit-proof manner, such that they can be accessed by the relevant parties.

A mechanism shall flag or alert compromised DPP data and DPPs.

4.8 Electronically signed data constructs (ESDCs)

4.8.1 Introduction to ESDCs

ESDCs are electronically signed documents or data sets. They are used to create a portable and verifiable digital representation of product-related information, attestations, or credentials. ESDCs are cryptographically signed by their issuing party, making them tamper-evident and digitally verifiable.

4.8.2 General services of ESDCs

Electronically signed data constructs (ESDCs) allow to:

— verify the DPP data integrity: by ensuring the data within the ESDC has not been altered after issuance;

— verify the DPP data issuer and provenance: by confirming the identity of the issuer of the ESDC and thus the source of the data;

— provide evidence of non-repudiation: the issuer cannot deny having issued the signed data, as in ISO/IEC 29115;

— verify the authority and accreditation of a DPP data issuer: by checking the status and attributes of the issuer's certificate against a trusted list or governance framework.

4.8.3 General implementation principles of ESDCs

An electronically signed data construct (ESDC) generally involves:

— Issuer: the entity asserting the claims or data contained within the ESDC, identified via a recognized identifier (see prEN 18219) linked to their signing key/certificate. In the DPP case, for core product data, the issuer is typically the economic operator that places the product on the market. Other authorized actors may issue specific attestations or updates as ESDCs.

— Subject: the product or item to which the claims or data refer, typically identified by a globally unique product identifier (e.g. as defined by prEN 18219).

oSIST prEN 18246:2025

— Data/Attributes: a set of attributes or information about the subject (e.g. DPP data such as material composition, recycling advice, conformity certificates).

— Proof/Signature: a digital signature ensuring the integrity and authenticity of the signed data. This signature is generated using the issuer's private key, corresponding to a public key whose certificate is managed within a recognized trust framework. The DPP ESDC should carry the digital signature of the responsible economic operator or authorized representative.

The structure of ESDCs depends on the data construct used to implement it and may be presented or exchanged as part of a larger collection of attestations.

EXAMPLES (W3C and ESDCs):

W3C Verifiable Credentials, as well as data constructs defined in ISO 22376 and ISO/IEC 20248, which may be used as verifiable identifiers, verifiable data carriers, or in association with a DPP data including mechanisms for linking to this DPP.

ESDCs are fundamental to ensuring trust in the DPP ecosystem. They provide a mechanism for validating the legitimacy and authority of the issuer as well as the integrity of the DPP data. Their use allows DPPs to be verified with common tools and devices, adapted to the specific ESDC technology chosen.

ESDCs can be implemented using various underlying technologies and standards. The choice of a specific ESDC technology may depend on the use case, data carrier constraints, existing infrastructure, and specific regulatory requirements.

5 Types of risk and requirements for unique product identifiers, data carriers and DPP Data

5.1 Risk on data security and privacy

5.1.1 General

These subclauses refer to any user using different ways to access public data of one or many DPPs of interest, when using common devices, such as smartphones using built-in capabilities, without requiring specialized applications.

These devices will follow the link enabled by the unique product identifier from the data carrier, as well as using any kind of online system or software to access DPP data from a server running on behalf of the economic operator or a DPP service provider.

The subclauses shall cover authentication access by legitimated users of a legitimate user groups to restricted data or even CRUD operations.

5.1.2 Protection of personal data

Implementation shall not gather any personal information from natural persons accessing public data only. In case of access to restricted data, authentication information may be requested.

5.1.3 Security of personal data

In case that personal data are gathered for permitted reasons, this data shall be secured against data loss, disallowed access and against any use not intended and not covered by permitted reasons.

Implementation and/or operator shall provide legal required information, correction and deletion possibilities for personal data.

DPP service shall not use external analytic tools and shall not include any reference to external components in the response to the user.

oSIST prEN 18246:2025

5.1.4 Security of organizational data

Ensuring the security of organizational data are crucial to protect sensitive business information, intellectual property, and operational processes from cyber threats.

Implementing robust cybersecurity measures, including encryption, access controls, and regular audits, helps safeguard data against unauthorized access and breaches.

5.1.5 Prevention of profiling

Given that combining IP addresses, HTTP protocol data, and user behaviour with access to a DPP may facilitate profiling in violation of privacy laws, such data practices shall be proactively prevented where technically feasible.

5.1.6 Ensuring safe user behaviour

Implementation shall avoid any request for personal data or execution rights on the user's device.

Users shall get used that entering data or allowing execution rights is never necessary to access public data of DPP. Additional information on this may be provided.

5.1.7 Protection against phishing, quishing, and malicious code

Protection against phishing, quishing, and malicious code involves implementing measures to prevent unauthorized access, data breaches, and fraudulent activities targeting users of the DPP system.

Phishing attempts aim to deceive users into disclosing sensitive information, while quishing targets QR codes and similar digital markers to redirect to malicious websites.

Effective protection includes user education, secure authentication mechanisms, regular system updates, and the use of trusted entry points to verify legitimate DPP access.

Anti-malware tools, network monitoring, and secure communication protocols further reduce the risk of malicious code infiltrating the system.

5.1.8 Safeguarding against mass data scraping

Mass data scraping poses a risk to the integrity and security of the DPP system by allowing unauthorized parties to extract sensitive product and consumer information on a large scale.

Robust anti-scraping mechanisms should be implemented to mitigate the risks.

Examples such as rate limiting systems, and access controls, ensure that only authorized users can retrieve data.

NOTE Continuous monitoring and adaptive security measures are necessary to detect and prevent scraping attempts, safeguarding both the privacy of individuals and the confidentiality of product data.

5.2 Risk and requirements on identification

5.2.1 General

Accurate identification of products, manufacturers, and other actors is crucial to ensure the integrity of the DPP system. Risks arise from incorrect or fraudulent identification, which can lead to the circulation of counterfeit goods or misrepresentations in the supply chain, affecting consumer trust and safety.

Appropriate and stringent requirements for reliable, secure, and verifiable identification mechanisms shall be implemented to mitigate the risks, leveraging unique identifiers and secure data protocols to ensure authenticity and traceability throughout the product lifecycle.

Identifiers should implement prEN 18220 and prEN 18219.

oSIST prEN 18246:2025

5.2.2 Authentication and traceability of responsible actors

Any actor liable for any restricted access above just requesting public data of a DPP shall be identifiable.

Each actor accredited for restricted access beyond the retrieval of public DPP data shall be identifiable. Authentication shall rely on registration with legally recognized trust services.

Authentication and identification shall not be limited to natural or legal persons within the European Union, as far as legal requirements are fulfilled.

5.2.3 Alignment between data providers and product manufacturers

The implementation should ensure proof of matching between DPP data provided and the product.

It should ensure proof of match between given DPP data and given product.

The alignment between the physical product, its identifier, and the associated DPP data, irrespective of the specific presentation format or data carrier used shall be ensured.

The implementation shall follow appropriate standards.

Common available identification systems of higher security status may also be used as an option.

5.3 Risk to products

5.3.1 Protecting against counterfeiting

There are three key aspects that shall be considered:

— trust framework: involving all stakeholders to establish a reliable and secure environment;

— data integrity: ensuring that data remains accurate and unaltered while maintaining interoperability;

— physical authentication: guaranteeing the verifiability of the physical product.

5.3.2 Risks to DPP-related product fraud

The purpose of DPP system is to establish a secure framework for creating and exchanging DPP-related information, ensuring its trustworthiness, authenticity and integrity.

The misuse of a valid DPP in association with counterfeit products may lead to significant risks to health, the environment, and the economy.

Where applicable or required, the DPP service shall include functionality to detect potentially suspicious requests and initiate appropriate measures, such as issuing alerts or triggering further investigation.

5.4 Risk and requirements related to fair competition

5.4.1 General

The implementation of DPPs shall ensure that all market participants have equal access to resources, tools, and data required for compliance.

5.4.2 Avoiding market restrictions by vendor specific software

Requiring vendor specific or commercial software could lead to market restrictions and undesirable advantages for large providers.

The basic functionality of searching and reading public DPP data shall be implementable in any DPP service in a form that is accessible without installing any commercial or vendor specific software.

oSIST prEN 18246:2025

5.4.3 Disproportionate resource demand for SMEs

Any implementation shall provide core functionalities described in the DPP standards in an easily accessible way.

Voluntary additional functionalities are allowed, but shall not replace core functionalities.

5.5 Risk and requirements to prevent exclusion

5.5.1 General

The system shall be accessible to all users, regardless of their technological capabilities, disabilities, or socioeconomic status. Additionally, stakeholders should be trained to understand and accommodate the diverse needs of users to minimize the risk of exclusion.

5.5.2 Accessibility to a DPP with any consumer device

Every natural person shall be able to access a DPP of interest at any time using a digital device, such as a smartphone, tablet, or computer.

Essential functionalities shall be readily accessible without the need for supplementary software.

5.5.3 Accessibility for persons with disabilities

Individuals with visual impairments shall be provided full access to DPPs.

Accordingly, the data carrier may include the features to facilitate location and scanning.

Additionally, any HTML response, if requested, shall be ARIA (Accessible Rich Internet Applications) compatible and fully accessible via screen readers.

Security mechanisms shall not prevent persons with disabilities to access the DPP information.

oSIST prEN 18246:2025

Annex A
(informative)

Examples of electronically signed data constructs (ESDCs)

A.1 General

This annex provides a non-exhaustive set of informative description of specific approaches and standards that can be used to implement electronically signed data constructs (ESDC) as described in 4.8.

The choice of a particular approach will depend on the use case requirements, regulatory mandates, existing infrastructure and data carrier constraints.

A.2 Electronic attestation of attributes

A.2.1 Introduction

Electronic attestation of attributes (EAA) is a trust service that provides a legally recognized mechanism for digitally attesting and verifying attributes (characteristics, qualifications, or entitlements) of natural persons, legal persons, or objects. EAAs enable the secure storage, exchange, and verification of these attributes.

A.2.2 Key characteristics

— **Issuer:** EAAs can be issued by anyone. In the DPP context there should be a level of assurance and legal recognition of the issuer.

NOTE For DPPs, the economic operator or another authorized entity usually acts as an EAA issuer.

— **Subject:** The product which the attributes refer to, identified by a globally unique product identifier as defined in prEN 18219.

— **Attributes/Claims:** An EAA contains specific attributes related to a subject (e.g. for a product: material composition, conformity status, repair history).

— **Format and Signing:** EAAs are digitally signed by an issuer to ensure authenticity and integrity. Specific technical formats for EAAs are being developed (e.g. ETSI standards like TS 119 471 for EAA Service Providers). W3C Verifiable Credentials (VCs) are widely considered a suitable technical format for representing EAAs.

— **Verification:** EAAs are verifiable against the issuer's public key/certificate, which in the case of qualified EAAs, is anchored in the EU's qualified trust ecosystem (Trusted Lists).

— **Legal Value:** Qualified EAAs have a defined legal value across the EU, equivalent to paper-based attestations.

A.3 Visible digital seal (VDS - ISO 22376)

A.3.1 Introduction to VDS

The visible digital seal (VDS), compliant with ISO 22376, is a representation of electronically signed data, optimized for visual carriers such as 2D barcodes (e.g. QR codes). It is designed to be tamper-evident and

oSIST prEN 18246:2025

digitally verifiable. Trust in the integrity and authenticity of the seal's data are achieved by issuing the VDS with an electronic signature anchored in a defined governance framework (e.g. compliant with ISO 22385).

A.3.2 Risk mitigation with VDS

Risks that VDS mitigates include:

- **Risks related to the authenticity of the link to the DPP:**
  - **Authenticity and verifiable origin of the link:** Ensured by the electronic signature included in every VDS, which validates the issuer of the seal (typically the economic operator). Verification of the signature confirms that the link to the DPP or the embedded data has not been altered since issuance.
- **Risks related to tampering with the identifier on the physical carrier:**
  - **Integrity of the embedded product identifier:** The VDS can contain the unique product identifier. The electronic signature protects this identifier against undetected modification.
  - **Reliable link between the physical product and the digital DPP:** The VDS provides a verifiable entry point on the product, reducing the risk of a counterfeit product being associated with an authentic DPP.
- **Risks related to illegitimate declarations:**
  - If the VDS includes signed conformity indicators or attestations, it contributes to the verification of their legitimacy.

A.3.3 Implementation of DPPs via VDS

A VDS typically consists of:

- **Seal issuer:** The entity responsible for creating and signing the VDS. In the DPP context, this is typically the economic operator placing the product on the market. Their identity is linked to the signing key.
- **Payload:** The data encoded within the VDS. This generally includes:
  - **A header** containing metadata about the seal (e.g. version, signature certificate identifier).
  - **Essential data** (e.g. the unique DPP product identifier, a secure web link to the full DPP, critical indicators).
- **Electronic Signature:** A digital signature that covers the payload, ensuring its integrity and authenticity. This signature is verifiable using the issuer's public key, whose certificate is managed within a trust framework.

The VDS is designed to be easily scanned and verified, for example, using a dedicated mobile application or an online service, allowing secure access to the associated DPP. Verification can often be performed offline if the necessary trust information (e.g. root public keys) is pre-loaded.

A.3.4 General services of VDS

VDS allows to:

oSIST prEN 18246:2025

— **verify the integrity of embedded data:** by ensuring that the product identifier or the link to the DPP has not been altered;

— v**erify the origin and provenance of the link/identifier:** by confirming the identity of the VDS issuer;

— **provide a secure and authenticated entry point to the DPP:** reducing risks of redirection to malicious sites or counterfeit DPPs;

— **facilitate verification by diverse actors:** including customs authorities, market surveillance authorities, and consumers, using common devices.

The VDS is an effective solution for securely linking a physical product to its digital passport, relying on established ISO standards for its structure (ISO 22376) and potentially its governance (ISO 22385).

A.4 Digital Signature Data Structure (DigSig - ISO/IEC 20248)

A.4.1 Introduction

ISO/IEC 20248 specifies a Digital Signature Data Structure (DigSig) for use with automatic identification and data capture (AIDC) techniques. It provides a method to digitally sign, structure, encode, and verify data within data carriers like barcodes (1D/2D), RFID tags, and NFC tags. DigSig aims to ensure the authenticity and integrity of the data carried, supporting offline verification where PKI elements are available.

A.4.2 Key characteristics

— **Issuer (domain authority - DA):** the entity responsible for issuing DigSigs and the associated certificates. The DA is identified by a unique identifier (DAID), often based on ISO/IEC 15459.

— **Data structure (DigSig data description - DDD):** DigSig uses a hierarchical, JSON-based data format (DDD) to define the structure and semantics of the information being signed and stored. This allows for flexible and extensible data payloads.

— **Encoding and snips:** the signed data are encoded into “snips” which are segments of the overall DigSig that can be distributed across one or more data carriers and memory pages of a data carrier.

— **Certificates (DigSig certificates):** uses public key certificates (typically X.509 compliant) as trust anchors for verification. The DA manages its own DigSig certificates.

— **Offline verification:** designed to support offline integrity checks using PKI, provided the necessary certificates (DA certificate, potentially root CAs) are accessible to the verifier.

— **Interoperability framework:** aims to allow secure track-and-trace, IoT authentication, and document verification.

A.4.3 DigSig as an ESDC for DPP

DigSig can function as an ESDC for the digital product passport by:

— encoding essential DPP data (e.g. unique product identifier, unique economic operator identifier, key attributes, link to full DPP) within its JSON-based DDD structure;

— securing this data with a digital signature from the Domain Authority (e.g. the economic operator);

oSIST prEN 18246:2025

— allowing this signed data to be embedded directly onto AIDC data carriers attached to the product;

— enabling verifiers to read the data carrier, parse the DigSig, and verify the signature against the DA's certificate to confirm data authenticity and integrity;

— providing a structured way to manage and update signed data associated with a product throughout its lifecycle if the data carrier supports updates.

The governance of DigSig relies on the Domain Authority managing its own identifier (DAID) and certificate issuance and ensuring the verifiability of its web presence for operational status checks. It can operate within broader PKI trust models, including national frameworks if the DA's certificates are appropriately anchored or cross-certified.

oSIST prEN 18246:2025

Annex ZA
(informative)

Relationship between this European Standard and the essential requirements of Regulation (EU) 2024/1781 establishing a framework for the setting of ecodesign requirements for sustainable products aimed to be covered

This European Standard has been prepared under a Commission's standardization request as regards digital product passports in support of Union policy on ecodesign requirements for sustainable products and on batteries and waste batteries (M/604) to provide one voluntary means of conforming to the essential requirements of Regulation (EU) 2024/1781 establishing a framework for the setting of ecodesign requirements for sustainable products.

Once this standard is cited in the Official Journal of the European Union under that Regulation, compliance with the normative clauses of this standard given in Table ZA.1 confers, within the limits of the scope of this standard, a presumption of conformity with the corresponding essential requirements of that Regulation and associated EFTA regulations.

Table ZA.1 — Correspondence between this European Standard and Article 10 and Article 11 of Regulation (EU) 2024/1781 establishing a framework for the setting of ecodesign requirements for sustainable products

Essential requirements of Regulation (EU) 2024/1781	Clause(s)/subclause(s) of this EN	Remarks/Notes
Article 11(g)	Clauses 4, 5	
Article 11(h)	Clauses 4, 5	

WARNING 1 — Presumption of conformity stays valid only as long as a reference to this European Standard is maintained in the list published in the Official Journal of the European Union. Users of this standard should consult frequently the latest list published in the Official Journal of the European Union.

WARNING 2 — Other Union legislation may be applicable to the products falling within the scope of this standard.

oSIST prEN 18246:2025

Bibliography

[1] ISO 22376, *Security and resilience — Authenticity, integrity and trust for products and documents — Specification and usage of visible digital seal (VDS) data format for authentication, verification and acquisition of data carried by a document or object*

[2] ISO 22380:2018, *Security and resilience — Authenticity, integrity and trust for products and documents — General principles for product fraud risk and countermeasures*

[3] ISO/IEC 20248, *Information technology — Automatic identification and data capture techniques — Digital signature data structure schema*

[4] ISO/IEC 29115, *Information technology — Security techniques — Entity authentication assurance framework*

[5] prEN 18219, *Digital product passport - Unique identifiers*

[6] prEN 18222, *Digital Product Passport - Application Programming Interfaces (APIs) for the product passport lifecycle management and searchability*

[7] prEN 18239, *Digital Product Passport - access rights management, information system security, and business confidentiality*

[8] ETSI EN 319 401:2024, *Electronic Signatures and Infrastructures (ESI); General Policy Requirements for Trust Service Provider*